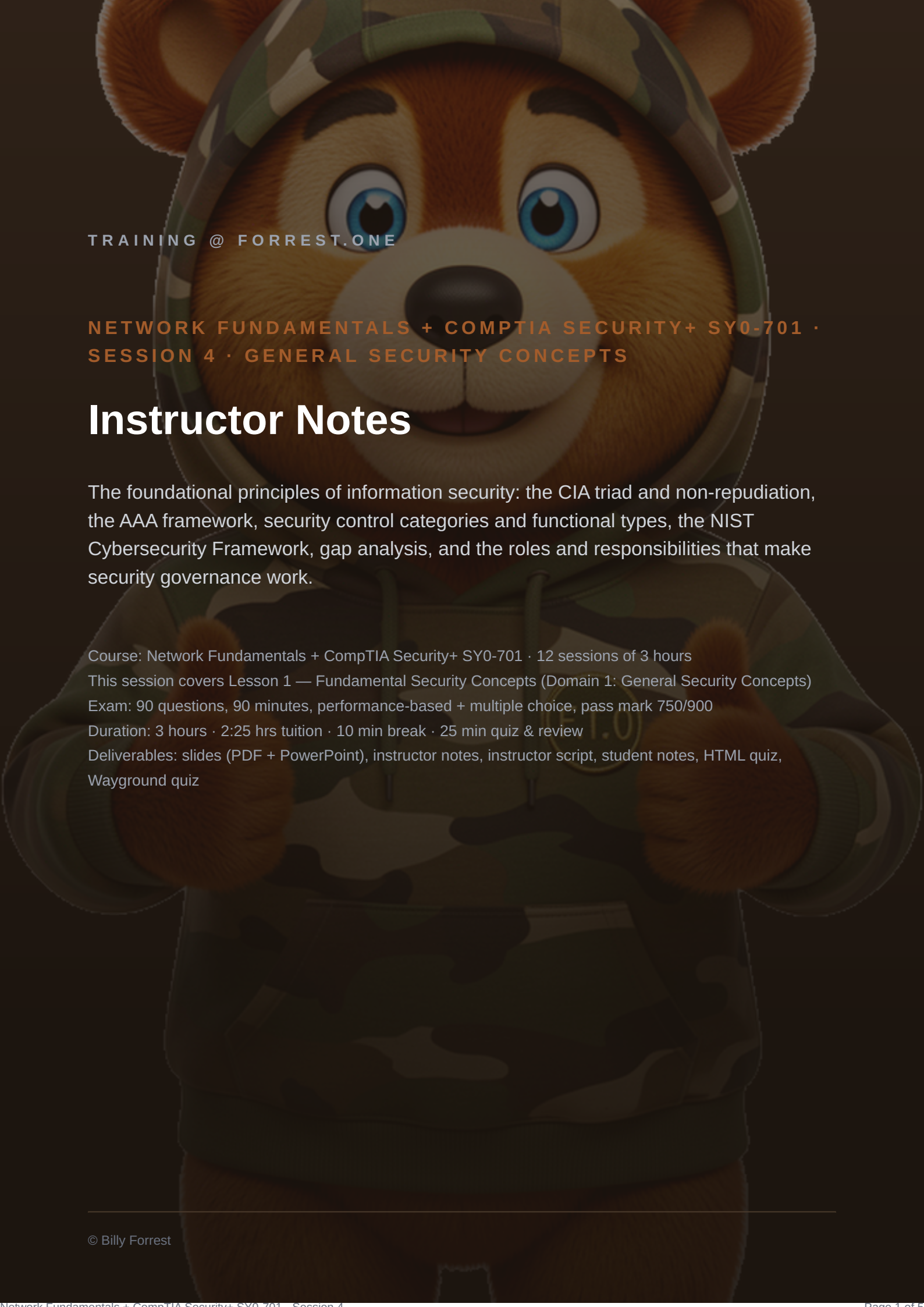




TRAINING @ FORREST.ONE

NETWORK FUNDAMENTALS + COMPTIA SECURITY+ SY0-701 ·
SESSION 4 · GENERAL SECURITY CONCEPTS

Instructor Notes

The foundational principles of information security: the CIA triad and non-repudiation, the AAA framework, security control categories and functional types, the NIST Cybersecurity Framework, gap analysis, and the roles and responsibilities that make security governance work.

Course: Network Fundamentals + CompTIA Security+ SY0-701 · 12 sessions of 3 hours

This session covers Lesson 1 — Fundamental Security Concepts (Domain 1: General Security Concepts)

Exam: 90 questions, 90 minutes, performance-based + multiple choice, pass mark 750/900

Duration: 3 hours · 2:25 hrs tuition · 10 min break · 25 min quiz & review

Deliverables: slides (PDF + PowerPoint), instructor notes, instructor script, student notes, HTML quiz, Wayground quiz

Instructor Notes — Fundamental Security Concepts

A 3-hour delivery guide for Session 4. This session sets the vocabulary the whole course depends on. Keep it interactive: classify controls, map incidents to CIA pillars, and relate every concept to the candidates' own workplaces. The deck follows the session video chapter for chapter, so the slides can be used alongside the recording.

Session at a glance

Time	Block	Slides	Focus / activity
0:00–0:15	Welcome & course map	1–3	12-session journey; exam facts; objectives
0:15–0:35	Why controls exist	4–5	Safeguards, threats, the layered view; activity preparation
0:35–1:05	Control categories	6–9	Technical, physical, managerial, operational
1:05–1:30	Control types	10–16	Six functional types; classification activity
1:30–1:50	Identity and proof	17–23	CIA, non-repudiation, authentication factors; discussion
1:50–2:00	Break	24	10-minute break
2:00–2:20	Accounting & zero trust	25–28	Audit trails, log management, never trust always verify
2:20–2:45	Deception & change control	29–34	Honeypots; four steps of a controlled change
2:45–2:55	Exam alignment	35–39	CSF, gap analysis, principles, roles, objective map
2:55–3:00	Quiz & close	40–43	Quiz_Session_04.html; takeaways; checklist; preview

Materials and preparation

- Projector or screen with the Session 4 slide deck (02_Slides.pdf or 02_Slides.pptx).

- One computer or tablet per pair for Quiz_Session_04.html (any browser, no internet required).
- Printed or digital copy of the Student Notes for each candidate.
- Whiteboard or flipchart for the control-classification activity.
- The official SY0-701 exam objectives document for reference.
- Optional: the NIST CSF 2.0 quick start guide for the gap analysis discussion.

Delivery guidance by slide

Slides 1–3 · Welcome (15 minutes)

Set the exam facts early: 90 questions, 90 minutes, performance-based items, pass mark 750. Walk the 12-session map and show how the five domains map across it. Emphasise that Security+ is vendor-neutral. Read out the eight session objectives so candidates can see that everything in the quiz comes from this list.

Slides 4–5 · Why controls exist (20 minutes)

Open with the question the video opens with: what actually stops an attack? Establish that a control is any safeguard or countermeasure that manages risk, that threats arrive from outside (a ransomware crew) and inside (a trusted employee copying files), and that controls are not only technical. Then take the layered view table slowly: layered defence, controls in concert, defence in depth, risk reduction. The redbox line is the one to repeat: one control is never enough.

Slides 6–9 · Control categories (30 minutes)

Category answers how a control is delivered. Technical controls are enforced by the system with no person in the loop: firewalls, encryption, ACLs, IDS. Physical controls protect premises, hardware and people: locks, fences, cameras, mantraps, biometric door access. Managerial controls (many organisations say administrative) are the policies and procedures: risk assessment, security policy, training. Operational controls are the day-to-day work that makes policy real: guard patrols, incident response, backup routines. Stress the pairing on slide 9: managerial writes the policy, operational carries it out.

Slides 10–16 · Control types (25 minutes)

Type answers what a control does. Preventive is proactive and acts before an incident: firewall, encryption, training, segmentation, and note honestly that prevention is never perfect. Detective finds what prevention missed: log monitoring, IDS, security audits. Corrective repairs the damage: patch, restore, revise the runbook, and revise is the step organisations skip. Compensating covers a gap when the proper control is not feasible: protect the link for a legacy system, enhanced logging when there is no budget, cameras where production cannot stop. Deterrent works on the attacker's mind: warning banners, visible cameras, security personnel. Directive points inwards at your own people: acceptable use policy, procedures. The activity on slide 16 fixes the two-axis model through classification.

Activity (slide 16)

Classify: firewall = technical/preventive; camera = physical/deterrent; IDS = technical/detective; backup-and-restore = operational/corrective; secure gateway for a legacy system = compensating. 8 minutes in pairs, 4 minutes debrief, then add workplace examples to each category.

Slides 17–23 · Identity and proof (20 minutes)

The triad is the anchor of the whole course. Take time on slide 18's table so every pillar has a concrete threat and a concrete control, and note that version control is an integrity control, not just a developer convenience. Non-repudiation is a frequent exam term: link it to the digital signature mechanism (hash encrypted with the private key, verified with the public key) and to audit logs and timestamps, never to logging alone. Slide 20 gives the analyst's view: contracts, payment authorisations and regulated records all depend on proof. Then the three authentication factors, with the warning that two passwords are not multifactor, and the protocol table: Kerberos, LDAP, SAML and SSO.

Discussion prompt (slide 23)

"Which pillar fails first in a typical breach?" Work through examples: stolen credentials hit confidentiality first, then integrity (data altered) and availability (systems locked). Real incidents chain across pillars.

Slides 25–28 · Accounting and zero trust (20 minutes)

Accounting is the third letter of the triple A framework and the one candidates under-rate. Its output is the audit trail: accountability, investigation, compliance and policy violations. Log management has three jobs: centralise, set a retention period, analyse, with a SIEM collecting and correlating events and alerting. Close the loop with the line candidates remember: a log nobody reads is evidence you will not have. Zero trust then removes implicit trust altogether: no user and no device trusted by default, microsegmentation to stop lateral movement, continuous verification with adaptive authentication, and least privilege. Be honest about the trade-off: complexity, cost and culture. Zero trust is a design principle, not a product.

Slides 29–34 · Deception and change control (25 minutes)

Deception technologies mislead an attacker deliberately: a honeypot is a decoy system, a honeynet is a network of them, a honeytokens is a single piece of fake data. The tell is that no legitimate user should ever reach them, and the returns are early warning, threat intelligence and wasted attacker effort. Then change management, which is where a great many real incidents begin. Walk the four steps on slide 31: request, impact assessment, approval, scheduled implementation with a rollback plan, and documentation throughout. Slide 32 shows the cost of skipping the process: unauthorised firewall rules, unapproved software, configuration drift. Slide 33 lists what a change can break: allow list, firewall rules, security baseline, dependencies. Slide 34 gives the two habits: test in a non-production environment, and evaluate security impact before approving, not after.

Slides 35–39 · Exam alignment (10 minutes)

The five CSF functions are a memorisation anchor with practical value; note that CSF 2.0 is now six functions with Govern added, but the exam expects the core five. Gap analysis is a programme-level measure, not a vulnerability scan. Return to the four principles and make the separation-of-duties point explicit, because the

quiz tests it. Then owner against custodian (accountability against implementation), a classic exam distinction, and the objective map on slide 39.

Slides 40–43 · Quiz and close (25 minutes)

Run the quiz, review low scores, walk the seven takeaways and assign the workplace-mapping checklist. Preview Session 5: threat actors, attack surfaces and the vulnerability-threat-risk relationship.

Common misconceptions and corrections

Misconception	Correction
"Integrity means data is correct"	Integrity means data is unchanged, correct is a separate property
"Non-repudiation is just logging"	Non-repudiation is proof of origin and action, signatures plus logs
"Preventive and deterrent are the same"	Preventive physically blocks; deterrent psychologically discourages
"A vulnerability scan is a gap analysis"	A scan finds technical holes; a gap analysis measures programme maturity against a framework
"The data owner stores the data"	The owner is accountable; the custodian implements the controls
"Zero trust is a product"	Zero trust is a design principle, verify every request
"A honeypot is a scanner"	A honeypot is a decoy that waits; no legitimate user should ever touch it
"Change management is only about downtime"	It also protects the allow list, firewall rules, security baseline and dependencies
"Managerial and operational controls are the same"	Managerial writes policy; operational carries it out day to day

Exam alignment check

- All session objectives map to Domain 1 objectives (1.1–1.4).
- Quiz tags map every question to its exam objective for traceable revision.
- The session stays vendor-neutral, no product-specific knowledge required.
- Common distractors to rehearse: preventive versus deterrent, integrity versus correctness, owner versus custodian, scan versus gap analysis, managerial versus operational.
- Zero trust and non-repudiation are repeated exam terms, return to them in every revision.
- The two-axis control model is the highest-yield idea in the session: category then type.